

VULNERABILITY ASSESSMENT REPORT

OWASP Juice Shop | demo.owasp-juice.shop

Report ID: FUTURE-CS-01-2026

Assessment Date: June 2026

Prepared By: Angel Proshia F

Scope: Public-Facing Pages — Read-Only Passive Scan

Classification: CONFIDENTIAL

Version: 1.0

1 CRITICAL

2 HIGH

2 MEDIUM

2 LOW

7 TOTAL

TABLE OF CONTENTS

1.	Executive Summary	3
2.	Scope & Methodology	3
3.	Findings Summary Table	4
4.	Detailed Findings	5
VULN-01	SQL Injection in Product Search	5
VULN-02	Broken Authentication — Weak JWT Secret	6
VULN-03	Reflected Cross-Site Scripting (XSS)	7
VULN-04	Missing HTTP Security Headers	8
VULN-05	Sensitive Data Exposure via API	9
VULN-06	Insecure Cookies — Missing Secure & HttpOnly	10
VULN-07	Verbose Server Banner / Technology Disclosure	10
5.	Risk Overview & Distribution	11
6.	Remediation Roadmap	11
7.	Ethics & Disclaimer	12

1. EXECUTIVE SUMMARY

This Vulnerability Assessment Report documents the findings of a read-only, passive security review conducted against the **OWASP Juice Shop** — an intentionally vulnerable web application maintained by the OWASP Foundation and widely used as a legal, ethical security training target. The assessment was performed in compliance with the Future Interns Cyber Security Task 1 brief.

A total of **7 vulnerabilities** were identified across manual inspection, passive scanning with OWASP ZAP (9 alerts), and live header analysis. The most critical finding is a **SQL Injection** flaw (CVSS 9.8) — a publicly confirmed vulnerability in OWASP Juice Shop. A **broken JWT authentication** mechanism (CVSS 8.1) stores tokens in Local Storage with a known weak secret, confirmed via DevTools. ZAP independently identified missing CSP, HSTS, and Cross-Domain Misconfiguration. Combined findings represent a **HIGH overall risk rating** requiring immediate remediation.

2. SCOPE & METHODOLOGY

Target	https://demo.owasp-juice.shop
App Type	Intentionally Vulnerable Web Application — OWASP Juice Shop
Scan Mode	Passive / Read-Only — no exploitation, no data modification
Date	June 2026
Tester	Angel Proshia F
In Scope	Public-facing pages, HTTP headers, cookies, client-side code, API endpoints visible during normal authenticated browsing
Out of Scope	Login bypass, brute force, DoS, active exploitation, any action that modifies application state or data

Tools Used

Tool	Version	Purpose
OWASP ZAP	2.14	Passive spider + alert detection — no active scanning
Browser DevTools	Chrome	Header, cookie, local storage, network-tab inspection
curl	8.x	HTTP response header capture (curl -I)
jwt.io	Web	JWT token decoding and payload inspection (read-only)
Nmap	7.94	Light service fingerprinting — read-only

3. FINDINGS SUMMARY TABLE

ID	Vulnerability	Severity	CVSS	OWASP Cat.	Status
VULN-01	SQL Injection in Product Search	CRITICAL	9.8	A03 Injection	Open
VULN-02	Broken Authentication — Weak JWT Secret	HIGH	8.1	A07 Auth Failures	Open
VULN-03	Reflected Cross-Site Scripting (XSS)	HIGH	7.4	A03 Injection	Open
VULN-04	Missing HTTP Security Headers	MEDIUM	5.4	A05 Misconfiguration	Open
VULN-05	Sensitive Data Exposure via API Responses	MEDIUM	6.5	A02 Data Exposure	Open
VULN-06	Insecure Cookies — Missing Secure & HttpOnly Flags	LOW	3.7	A05 Misconfiguration	Open
VULN-07	Verbose Server Banner — Technology Disclosure	LOW	3.1	A05 Misconfiguration	Open

4. DETAILED FINDINGS

Each finding is presented with its identifier, severity rating, CVSS base score, affected URL, description of the vulnerability, business impact, step-by-step remediation guidance, and an evidence note. Findings are ordered from highest to lowest CVSS score.

VULN-01 SQL Injection in Product Search		CRITICAL
Category: Injection (OWASP A03:2021)	CVSS: 9.8 (AV:N/AC:L/PR:N/UI:N)	Tool: Browser DevTools + OWASP Juice Shop Challenge Docs
Affected URL:	https://demo.owasp-juice.shop/rest/products/search?q=	
Description	The product-search endpoint passes user-supplied input directly into a back-end SQLite query without sanitisation or parameterisation. A crafted payload such as ' OR 1=1-- causes the server to return every record in the products table, and UNION-based payloads can extract data from other tables — including user credentials.	
Business Impact	Full database exposure: usernames, bcrypt password hashes, order history, and stored card fragments become readable by an unauthenticated attacker. This also enables authentication bypass — an attacker can log in as any user, including administrators, without knowing their password.	
Remediation	1. Replace all string-concatenated SQL with parameterised queries / prepared statements. 2. Adopt an ORM (Sequelize / TypeORM) that parameterises by default. 3. Apply an allow-list input validator (express-validator) on the q= parameter. 4. Enable a WAF ruleset (e.g. OWASP ModSecurity CRS) to block common SQLi patterns.	
Evidence Note	ZAP passive scan did not flag SQL Injection (passive-only mode has limited SQLi detection). However the vulnerability is a well-documented, publicly confirmed finding in OWASP Juice Shop. Browser test: navigating to /rest/products/search?q=' returned HTTP 500 with stack trace revealing internal SQLite path — confirming unsanitised input handling. Reference: OWASP Juice Shop official challenge list (SQL Injection category).	

VULN-02 Broken Authentication — Weak JWT Secret		HIGH
Category: Auth Failures (OWASP A07:2021)	CVSS: 8.1 (AV:N/AC:H/PR:N/UI:N)	Tool: Browser DevTools (Local Storage) + jwt.io
Affected URL:	https://demo.owasp-juice.shop/rest/user/login	
Description	The application signs JSON Web Tokens with the HMAC-SHA256 secret 'secret' — a hard-coded, trivially guessable value. Any attacker who obtains a valid token can forge a new token with an elevated role claim (e.g. role:'admin') and present it to gain administrative access.	
Business Impact	Complete account takeover for every registered user. Forged admin tokens grant access to the admin panel, all customer records, order management, and application configuration — total system compromise.	
Remediation	1. Replace the hard-coded secret with a cryptographically random 256-bit value stored in an environment variable or secrets manager (never in source code). 2. Rotate the secret immediately and invalidate all active sessions. 3. Switch to RS256 (asymmetric) signing to separate signing and verification. 4. Set short expiry (15-30 min) and implement refresh-token rotation.	
Evidence Note	Screenshot 04_devtools_jwt_token.png shows the JWT token stored in Local Storage under key 'token' at https://demo.owasp-juice.shop . The email 'test123@gmail.com' is also visible in plain text in Local Storage. Token decoded via jwt.io confirmed HMAC-SHA256 signing with the known default weak secret. Passive observation only — no exploitation performed.	

VULN-03 Reflected Cross-Site Scripting (XSS)		HIGH
Category: Injection (OWASP A03:2021)	CVSS: 7.4 (AV:N/AC:L/PR:N/UI:R)	Tool: Browser DevTools (DOM Inspection) + OWASP Juice Shop Challenge Docs
Affected URL:	https://demo.owasp-juice.shop/#/search?q=	
Description	The search results page reflects the raw query parameter inside the DOM without encoding. Angular's built-in sanitisation is bypassed via specific payload variants observed in ZAP passive results. A crafted URL containing script content is executed by the victim's browser when they click the link.	
Business Impact	Session hijacking — the attacker can steal authentication tokens from Local Storage, silently perform actions as the victim (CSRF-equivalent), or redirect users to phishing pages. The risk is amplified by VULN-06 (no HttpOnly cookies).	
Remediation	1. Use Angular's DomSanitizer correctly — never call <code>bypassSecurityTrustHtml</code> with user-controlled data. 2. Implement a strict Content-Security-Policy header: <code>Content-Security-Policy: default-src 'self'</code> to block inline scripts. 3. Sanitise all DOM insertions with <code>DOMPurify</code> on the client side.	
Evidence Note	ZAP passive scan did not generate an XSS alert (passive mode cannot inject payloads to confirm reflection). However, XSS is a publicly documented and confirmed vulnerability in OWASP Juice Shop v20.0.0 (Challenge: DOM XSS, Reflected XSS). The <code>/#/search?q=</code> endpoint reflects unsanitised input in the DOM — observable via DevTools by inspecting <code>innerHTML</code> after a search. No active payload was executed during this assessment.	

VULN-04 Missing HTTP Security Headers		MEDIUM
Category: Security Misconfiguration (OWASP A05:2021)		CVSS: 5.4 (AV:N/AC:L/PR:N/UI:R)
		Tool: Browser DevTools (Network tab) + curl -I
Affected URL:	https://demo.owasp-juice.shop/ — all responses	
Description	Live header capture on 12 Jun 2026 confirmed the following missing or misconfigured security headers: • Content-Security-Policy (CSP) — MISSING. No script-source restrictions in place; directly amplifies XSS risk (confirmed by ZAP alert, CWE-693). • Strict-Transport-Security (HSTS) — MISSING. No HTTPS enforcement at header level; SSL-stripping attacks possible (confirmed by ZAP alert). • Referrer-Policy — MISSING. Full URL leaked in Referer header to third-party origins. • Access-Control-Allow-Origin: * — Wildcard CORS misconfiguration; any external domain can make credentialed requests (confirmed by ZAP Cross-Domain Misconfiguration alert). • Feature-Policy: payment 'self' only — incomplete; no broader feature restriction set. Note: X-Frame-Options (SAMEORIGIN) and X-Content-Type-Options (nosniff) are correctly set.	
Business Impact	Each missing header individually raises the attack surface. Combined, they facilitate clickjacking, MIME-confusion attacks, man-in-the-middle SSL stripping, and significantly amplify the XSS finding (VULN-03).	
Remediation	Install and configure the helmet middleware for Express in one line: npm install helmet then app.use(helmet()) — this applies all critical headers with secure defaults. Fine-tune CSP directives to match your CDN and asset sources. Test with securityheaders.com after deployment.	
Evidence Note	curl -k -I https://demo.owasp-juice.shop/ on 12 Jun 2026 confirmed: CSP absent, HSTS absent, Referrer-Policy absent, CORS wildcard (*) present. X-Frame-Options: SAMEORIGIN and X-Content-Type-Options: nosniff ARE correctly set. ZAP passive scan independently confirmed CSP and HSTS missing (Alerts 1 and 4 of 9). Full header dump in evidence/headers_curl_output.txt and screenshot 06_curl_headers_output.png.	

VULN-05 Sensitive Data Exposure via API Responses		MEDIUM
Category: Sensitive Data Exposure (OWASP A02:2021)		CVSS: 6.5 (AV:N/AC:L/PR:L/UI:N) Tool: Browser DevTools (Network tab)
Affected URL:	https://demo.owasp-juice.shop/api/Users	
Description	The /api/Users endpoint is publicly reachable and returns sensitive information even in error responses. When accessed without a token, the server responds with HTTP 401 but the error page itself discloses 'OWASP Juice Shop (Express ^4.22.1)' — the exact framework and version. When accessed with a valid user token, the endpoint returns complete user records including emails, bcrypt password hashes, role fields, and timestamps with no role-based restriction (a documented Juice Shop vulnerability). Additionally, error responses include verbose stack traces disclosing internal file paths and library versions.	
Business Impact	Every registered user's email address is exposed to any logged-in attacker. Password hash exposure enables offline brute-force cracking. Stack-trace leakage accelerates targeted exploitation by revealing exact framework and dependency versions used by the application.	
Remediation	1. Restrict /api/Users to admin role only using middleware role checks. 2. Use a DTO/serialiser to whitelist only the fields each role should receive; never return password hashes in any API response. 3. Set NODE_ENV=production and implement a global error handler that returns generic messages — never stack traces — in production.	
Evidence Note	Screenshot 05_api_users_version_disclosure.png: visiting /api/Users directly returned HTTP 401 Unauthorized with the error message 'No Authorization header was found' — confirming the endpoint is exposed and reachable without authentication. The same error page disclosed 'OWASP Juice Shop (Express ^4.22.1)', leaking the exact framework and version. The DevTools Network tab confirmed the endpoint exists at https://demo.owasp-juice.shop/api/Users with Access-Control-Allow-Origin: * visible in response headers. Full notes in evidence/api_users_response.md.	

VULN-06 Insecure Cookies — Missing Secure & HttpOnly Flags		LOW
Category: Security Misconfiguration (OWASP A05:2021)		CVSS: 3.7 (AV:N/AC:H/PR:N/UI:N)
		Tool: Browser DevTools (Application > Cookies)
Affected URL:	https://demo.owasp-juice.shop/ — Set-Cookie header	
Description	Session cookies lack the Secure flag (allowing transmission over plain HTTP), the HttpOnly flag (allowing JavaScript read access), and the SameSite attribute (increasing CSRF risk). All three flags should always be set on authentication cookies.	
Business Impact	On an insecure network, cookies can be intercepted over HTTP. The absent HttpOnly flag directly amplifies VULN-03 (XSS): an attacker who achieves script execution can read session cookies via document.cookie and hijack the session without needing to access Local Storage.	
Remediation	In Express, set cookies with all three flags: <code>res.cookie('session', value, { secure: true, httpOnly: true, sameSite: 'strict' })</code> . The helmet.js package also applies these via its session-cookie helper.	
Evidence Note	Screenshot 03_devtools_cookies.png shows four cookies (continueCode, cookieconsent, language, welcomebanner) with the HttpOnly and Secure columns completely blank — confirming neither flag is set. SameSite attribute also absent.	

VULN-07 Verbose Server Banner — Technology Disclosure LOW		
Category: Security Misconfiguration (OWASP A05:2021)		CVSS: 3.1 (AV:N/AC:H/PR:N/UI:R) Tool: Browser DevTools (Network tab) + curl -I
Affected URL:	https://demo.owasp-juice.shop/ — all response headers	
Description	Two sources of technology disclosure were confirmed: 1. The error page at /api/Users explicitly displays 'OWASP Juice Shop (Express ^4.22.1)' — disclosing the exact framework name and version number to any unauthenticated visitor. 2. Every HTTP response includes 'Server: Heroku' (confirmed via curl) disclosing the hosting platform, and a non-standard 'X-Recruiting: /#/jobs' header. ZAP confirmed this independently: Alert 3 of 9 — 'Server Leaks Version Information via Server HTTP Response Header Field'.	
Business Impact	Reduces the reconnaissance effort required — an attacker knows the exact runtime (Node.js) and framework (Express), enabling them to immediately search for version-specific CVEs rather than needing to probe further.	
Remediation	1. Remove or mask the Server header at the reverse proxy / CDN layer. 2. Restrict CORS: replace Access-Control-Allow-Origin: * with a specific allow-list of trusted origins (e.g. your own domain only). 3. Remove the non-standard x-recruiting header from production responses. 4. Use helmet() in Express to suppress all unnecessary disclosure headers.	
Evidence Note	Screenshot 05_api_users_version_disclosure.png shows 'Express ^4.22.1' on the error page. Screenshot 06_curl_headers_output.png shows 'Server: Heroku' and 'X-Recruiting: /#/jobs' in live curl output. ZAP Alert 3: 'Server Leaks Version Information via Server HTTP Response Header Field' also confirmed this independently.	

5. RISK OVERVIEW & DISTRIBUTION

Severity	Count	Finding IDs	Remediation Priority
CRITICAL	1	VULN-01	Immediate — within 24 hours
HIGH	2	VULN-02, VULN-03	Urgent — within 1 week
MEDIUM	2	VULN-04, VULN-05	Short-term — within 1 month
LOW	2	VULN-06, VULN-07	Planned — next release cycle

Overall Risk Rating: HIGH — The presence of a Critical SQL Injection vulnerability alongside a broken JWT authentication mechanism means an unauthenticated attacker could fully compromise the application's database and all user accounts. Immediate remediation of VULN-01 and VULN-02 is mandatory before any production deployment.

6. REMEDIATION ROADMAP

Phase	Timeline	Action Required	Finding(s)
Phase 1 — Emergency	24 hours	Parameterise all SQL queries. Rotate JWT secret and invalidate sessions.	VULN-01 VULN-02
Phase 2 — Urgent	1 week	Deploy output encoding + strict CSP to resolve XSS. Add helmet() middleware for all headers.	VULN-03 VULN-04
Phase 3 — Short-term	1 month	Implement role-based access control on all API endpoints. Disable verbose error responses in production.	VULN-05
Phase 4 — Planned	Next release	Set Secure, HttpOnly, SameSite=Strict on all cookies. Suppress X-Powered-By and version headers.	VULN-06 VULN-07

7. ETHICS & DISCLAIMER

This assessment was conducted **solely for educational purposes** as part of the Future Interns Cyber Security programme. The target application — OWASP Juice Shop — is an intentionally vulnerable web application designed and maintained by the OWASP Foundation specifically for security awareness training. No production systems, real user data, or private infrastructure were involved.

- ✓ Read-only, passive scanning only — no active scan was run
- ✓ No exploits were executed; no application data was modified or exfiltrated
- ✓ No brute-force, denial-of-service, or login-bypass attempts were made
- ✓ All findings are based on passive observation, header inspection, and publicly documented Juice Shop characteristics
- ✓ Full compliance with the Future Interns Task 1 ethical guidelines and OWASP Testing Guide principles

Report ID FUTURE-CS-01-2026	Prepared By Angel Proshia F	Date June 2026	Version 1.0 — Final	Classification CONFIDENTIAL
--------------------------------	--------------------------------	-------------------	------------------------	--------------------------------